

CYNA DEV

Document de Test

Synthèse de la campagne de tests réels — Bloc 3

Projet : CYNA DEV — Plateforme e-commerce SaaS de cybersécurité

Groupe : Charlotte Moerman · Nathan Noelijaona · Karl Negrevergne · Ylan Pernot

Version : 2.0 — remplace la version 1.0 (résultats de synthèse théoriques)

1. Introduction

Ce document synthétise une campagne de tests fonctionnels et de sécurité réellement exécutée contre le code de l'application CYNA DEV : un backend Node.js/Express a été démarré localement, connecté à une vraie base PostgreSQL initialisée avec le schéma exact du projet, et interrogé via de vraies requêtes HTTP (pas de simulation ni de résultats théoriques).

Ce document remplace une première version qui présentait des résultats et anomalies illustratifs. Les résultats ci-dessous sont tous issus de tests réellement exécutés ; le détail complet de chaque test (requête envoyée, réponse obtenue, vérifications en base de données) est disponible dans les 6 rapports de test annexés, un par module fonctionnel.

2. Périmètre et méthode

- Environnement : backend réel démarré (node server.js), PostgreSQL 16 réel, jeu de données de démonstration officiel du projet (seed-catalogue.sql).
- Méthode : requêtes HTTP réelles (fetch/curl) contre l'API en fonctionnement ; vérifications croisées directement en base de données lorsque pertinent (ex. anonymisation RGPD, tentative d'injection SQL).
- 54 tests exécutés au total, répartis en 6 modules fonctionnels.

3. Synthèse des résultats par module

Module	Tests	Conformes	Limités par l'environnement	Rapport détaillé
Authentification	15	15	0	Rapport de Test 01
Catalogue & Recherche	9	9	0	Rapport de Test 02
Espace Client & RGPD	10	10	0	Rapport de Test 03
Back-office Administrateur	9	9	0	Rapport de Test 04
Sécurité Applicative	6	6	0	Rapport de Test 05
Contact, Chatbot & Paiement	5	3	2	Rapport de Test 06
TOTAL	54	52	2	—

4. Ce qui a été vérifié en conditions réelles (points clés)

- Inscription, confirmation d'email, connexion, mot de passe oublié : parcours complet vérifié de bout en bout.
- Rate-limiting sur l'authentification : déclenchement réel confirmé (10 requêtes/15 min sur la connexion).
- Recherche full-text : temps de réponse mesuré à 6,7 ms en moyenne sur 10 requêtes (exigence du cahier des charges : < 100 ms — largement respectée).
- Anonymisation RGPD : vérifiée directement en base de données après appel de l'API, pas seulement via le code HTTP renvoyé.

- Injection SQL : tentative réelle sur le paramètre de recherche et sur le formulaire de connexion — neutralisée dans les deux cas, table intacte vérifiée en base.
- Injection XSS : payload réellement soumis au formulaire de contact ; stocké tel quel en base (l'API ne filtre pas), mais confirmé sans risque car aucun composant front-end n'utilise dangerouslySetInnerHTML (React échappe automatiquement à l'affichage).
- En-têtes de sécurité HTTP (Helmet) et politique CORS : vérifiés par inspection réelle des réponses HTTP.
- CRUD complet du back-office (produits) : create/read/update/delete tous testés avec succès.

5. Limites rencontrées et non testées de bout en bout

Fonctionnalité	Raison	Ce qui a pu être vérifié malgré tout
Chatbot IA (Ollama)	Le serveur Ollama (LLM local) n'est pas installé dans l'environnement sandbox utilisé pour ces tests	L'API ne plante pas en cas d'indisponibilité du LLM ; l'erreur est gérée proprement (réponse HTTP explicite)
Paiement Stripe de bout en bout	L'environnement sandbox bloque les connexions sortantes vers api.stripe.com (règle réseau)	Aucune commande fantôme n'est créée en base si l'appel Stripe échoue ; la vérification de signature du webhook fonctionne indépendamment du réseau

Ces deux points nécessitent d'être rejoués dans un environnement disposant d'un accès réseau sortant complet (ou via Docker Compose, qui embarque son propre conteneur Ollama et un relais de webhooks Stripe automatique — voir le Guide d'Utilisation).

6. Anomalies détectées

Aucune anomalie de sécurité ou de logique métier n'a été détectée dans le code de l'application au cours de cette campagne. Les seules erreurs rencontrées pendant les tests provenaient des scripts de test eux-mêmes (mauvais nom de route ou de champ dans une requête), corrigées immédiatement — elles sont documentées à titre de traçabilité dans les rapports détaillés, mais ne constituent pas des anomalies de l'application.

7. Conclusion

52 tests sur 54 ont été exécutés avec succès en conditions réelles, sans qu'aucune anomalie de l'application ne soit détectée. Les 2 tests restants (chatbot, paiement de bout en bout) sont limités par l'environnement de test et non par un défaut du code ; les mécanismes de résilience associés (gestion d'erreur, intégrité transactionnelle) ont néanmoins été vérifiés avec succès. Le niveau de qualité observé est jugé conforme aux attentes du cahier des charges.

8. Annexes

- Rapport de Test 01 — Authentification
- Rapport de Test 02 — Catalogue & Recherche
- Rapport de Test 03 — Espace Client & RGPD

- Rapport de Test 04 — Back-office Administrateur
- Rapport de Test 05 — Sécurité Applicative
- Rapport de Test 06 — Contact, Chatbot & Paiement